

# MetaPod

## Application-wide attestation of Kubernetes applications

*including work by*

Henrik Niskanen, Ghazal Shenavar, Huy Ngo, Merlijn Sebrechts, Lachlan J. Gunn

6.10.2026

<https://lachlan.gunn.ee>  
[lachlan@gunn.ee](mailto:lachlan@gunn.ee)



Funded by  
the European Union

This work was supported in part by: Smart Networks and Services Joint Undertaking (SNS JU) under the ELASTIC (Grant No. 101139067) project. The views expressed in this work are those of the authors and do not necessarily reflect the official position of the projects or the funding bodies.

# Trusted Execution Environments

1. **Isolation:** the ability to run trusted code strongly isolated from everything outside
2. **Secure Storage:** the ability to store data, ensuring integrity and confidentiality
3. **Attestation:** the ability to convince another party of the above attributes, and the characteristics of the trusted software protected by them

# Example: Intel Trust Domain Extensions (TDX)

Brings together several CPU extensions to create Confidential VMs (CVMs)

## Virtual Machine Extensions (VMX)

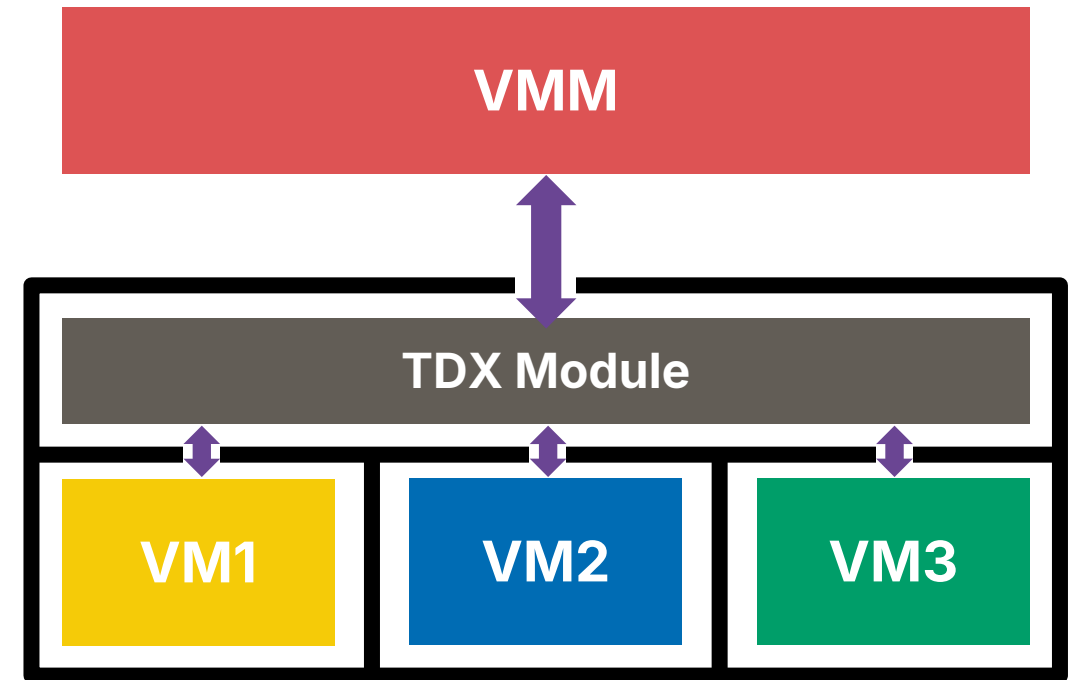
- Instructions supporting virtualization
  - E.g. additional page-tables controlled by VMM
  - Additional modes: root (VMM), non-root (VMs)

## Total Memory Encryption (TME)

- Transparently encrypts memory
- Each VM uses different keys

## Secure-Arbitration Mode (SEAM)

- Used to protect a trusted "TDX Module"
  - Contains security-sensitive hypervisor primitives
- Code must be signed by Intel



# Confidential Containers

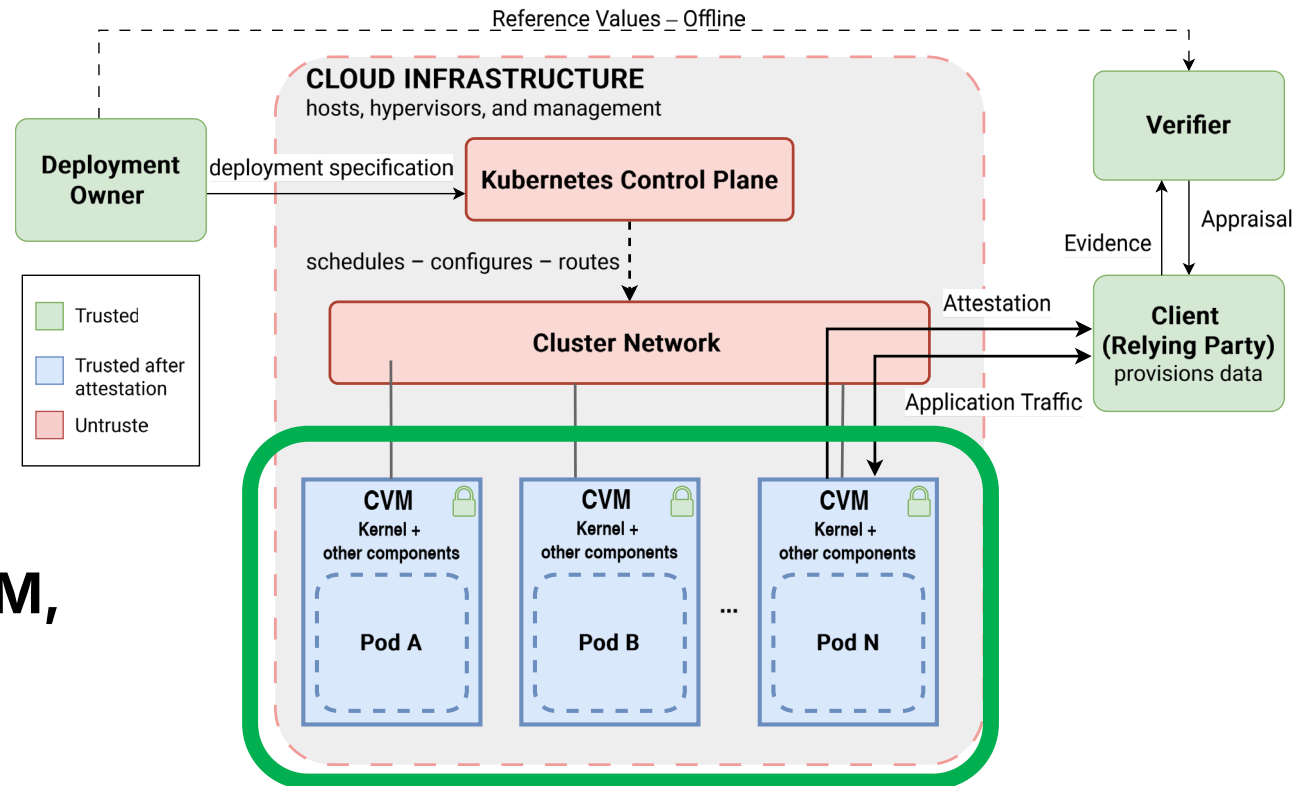
## Kata-containers deploys pods as CVMs

- Agent in CVM to start containers

## Hardware protects them from

- Other workloads
- Hypervisor

**Problem:** Cluster can start normal VM, and just say it's protected



# Remote attestation

HW = Intel  
OS = kata-tdx  
App = 88a46...



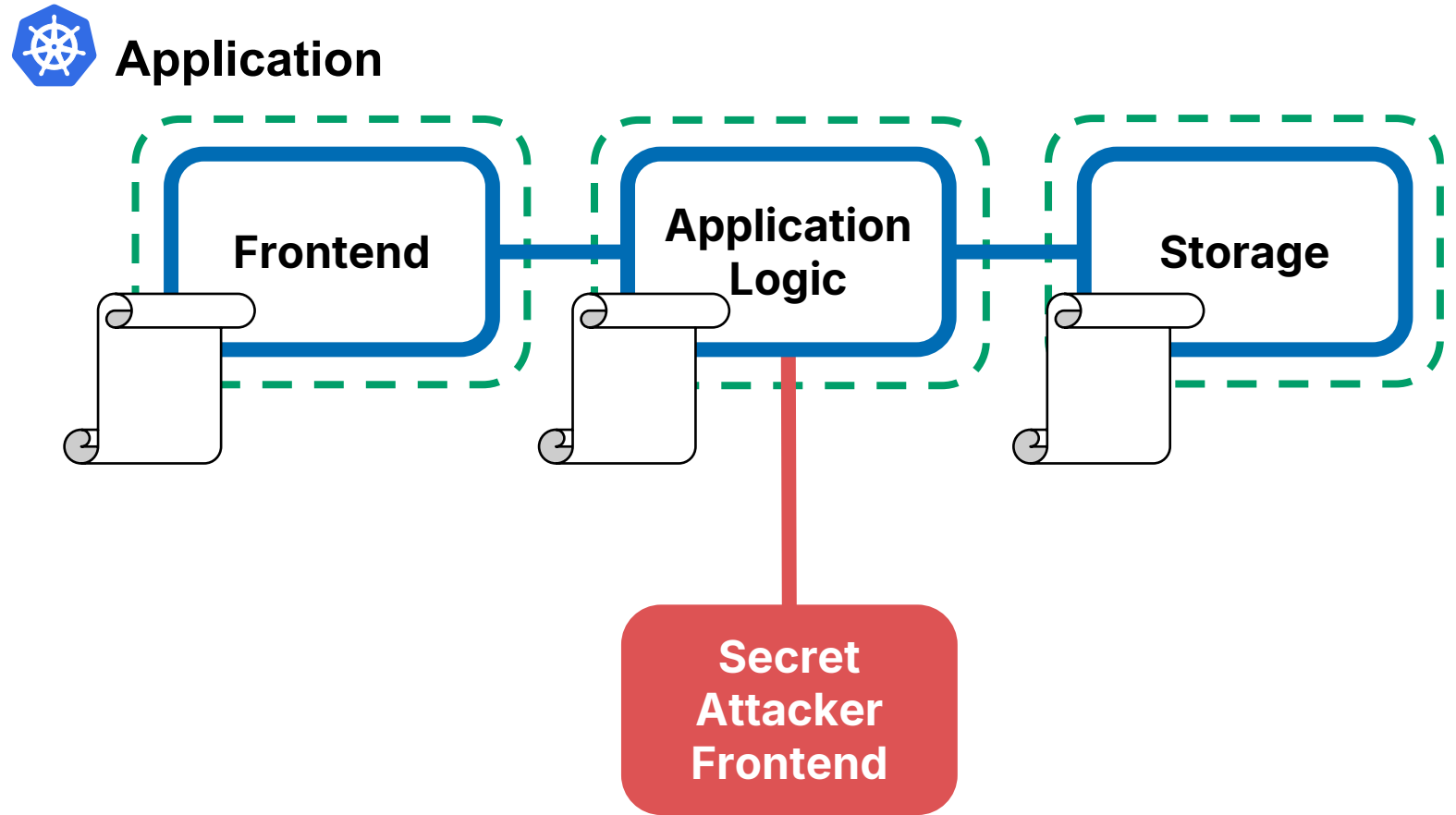
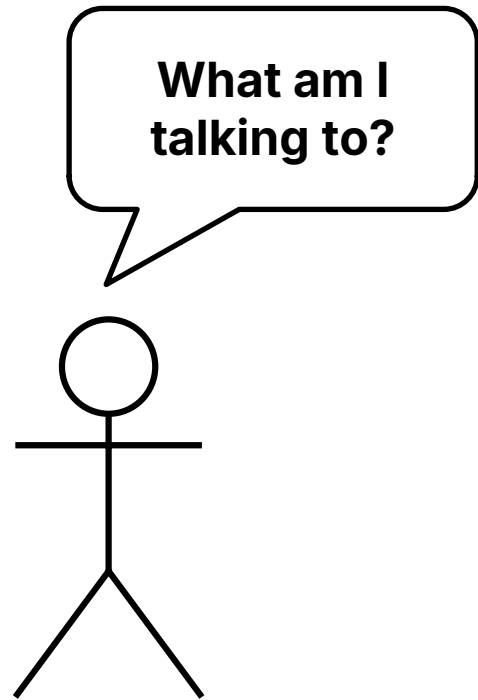
**Prover**



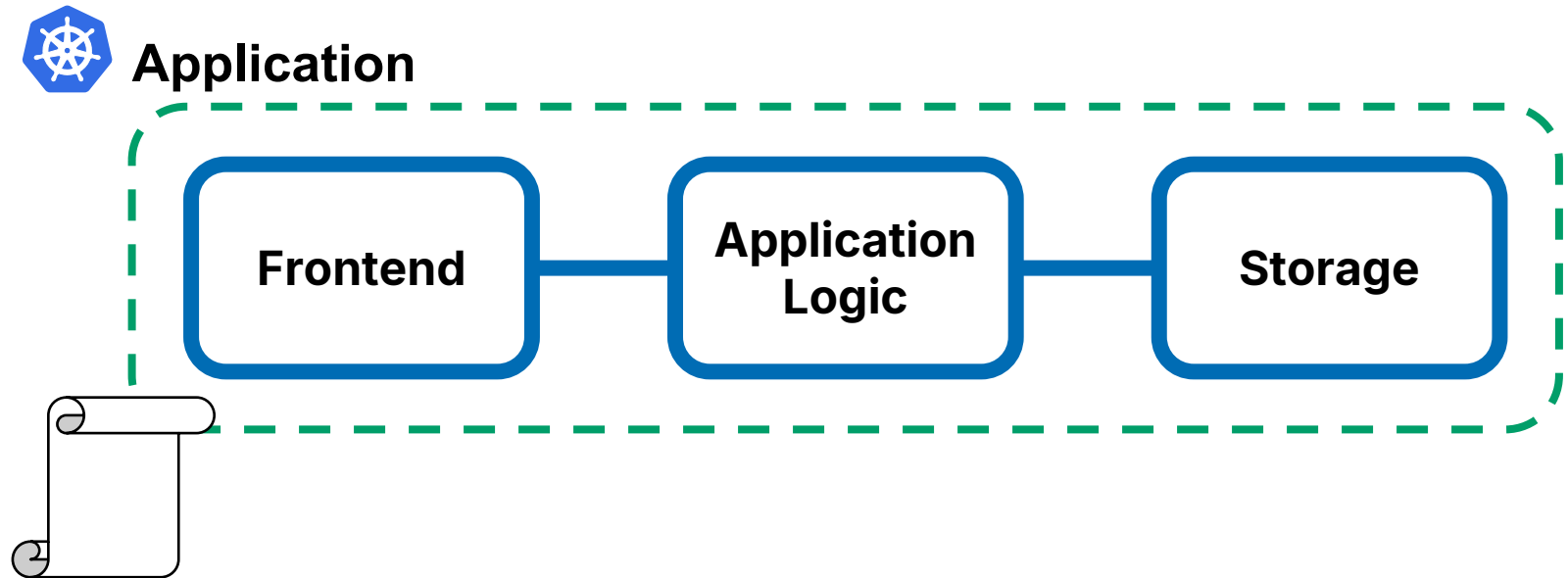
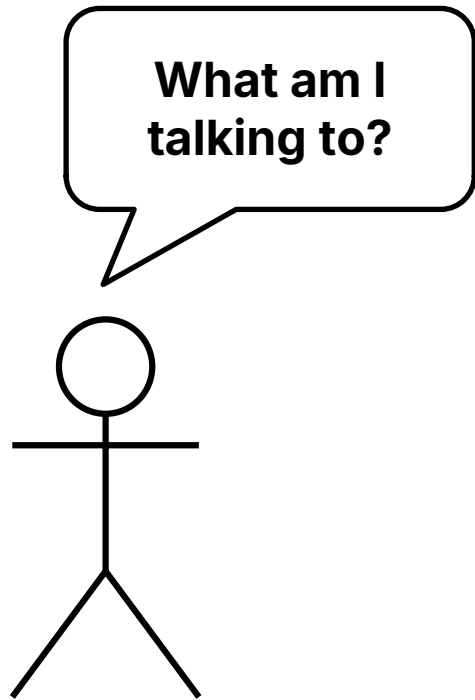
**Verifier**

**I'm talking to...**  
HW = Intel  
OS = kata-tdx  
App = 88a46...

# Attesting multi-pod applications



# Attesting multi-pod applications



# Application-wide attestations

## 1. Deploy pods to CVMs

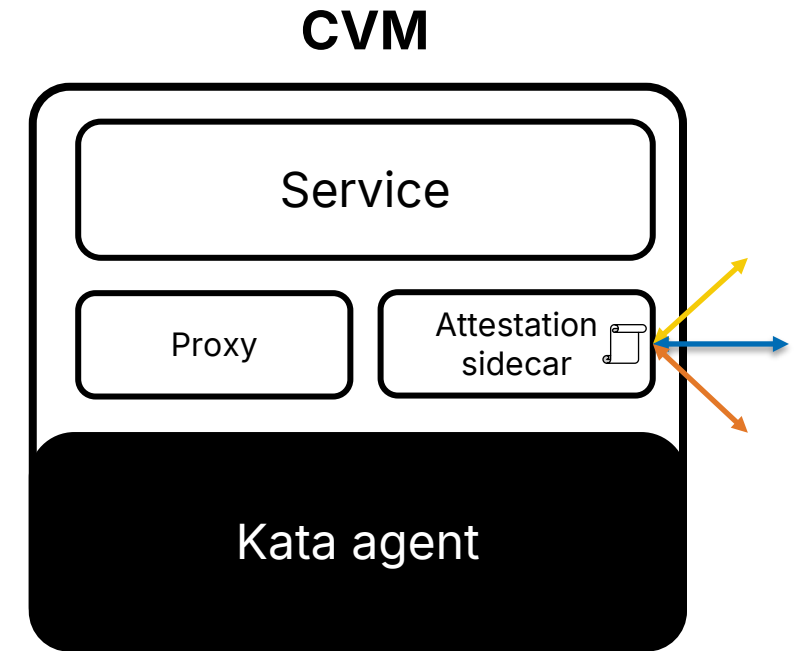
- Each pod: Service + sidecar + proxy
- Generate keypairs, send to other CVMs

## 2. Attest proxy configuration, send to CVMs

- Goal: proving that all CVMs have **consistent proxy configuration**
- Matching attestations => all CVMs agreed on which instance provides which service

## 3. Apply configuration to proxy

- Services can now only communicate according to the agreed-on configuration



# MetaPod instantiation

## Kata policy

- Part of the CVM configuration
- Limit which pods run in the CVM

## Attestation sidecar

- Runs the attestation protocol

# Network Proxy envoy

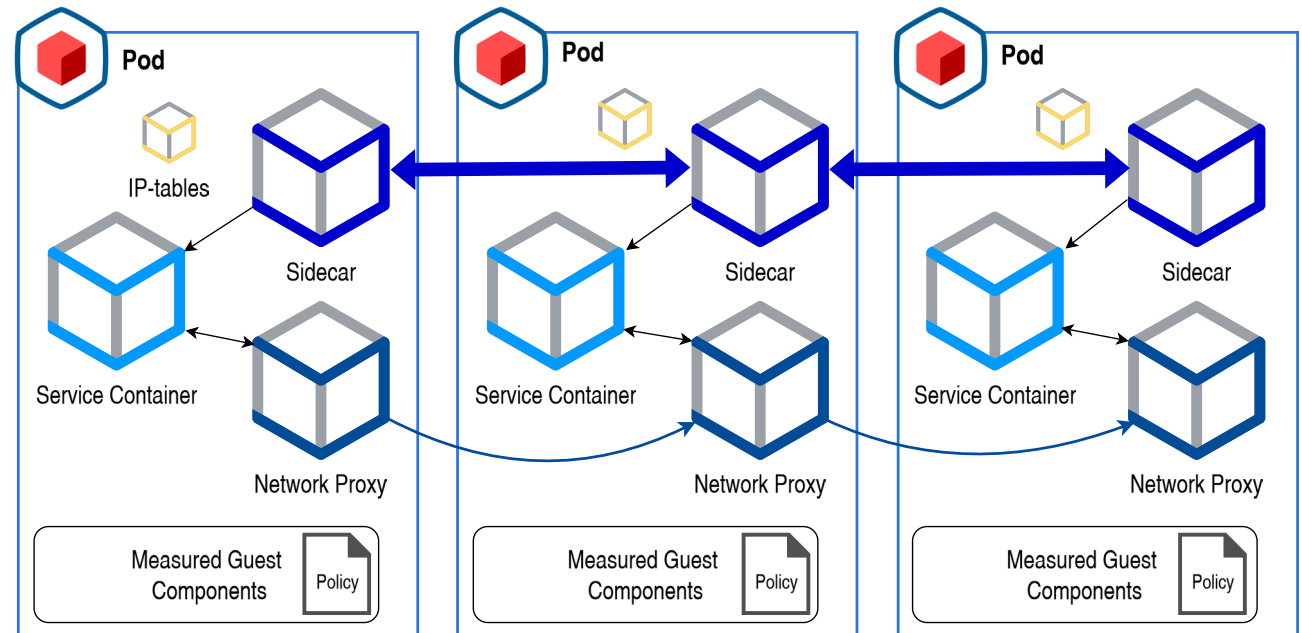
- Secure traffic between pods

## Init container

- Installs network rules

## Application is left unchanged

- Can request manifest from attestation sidcar



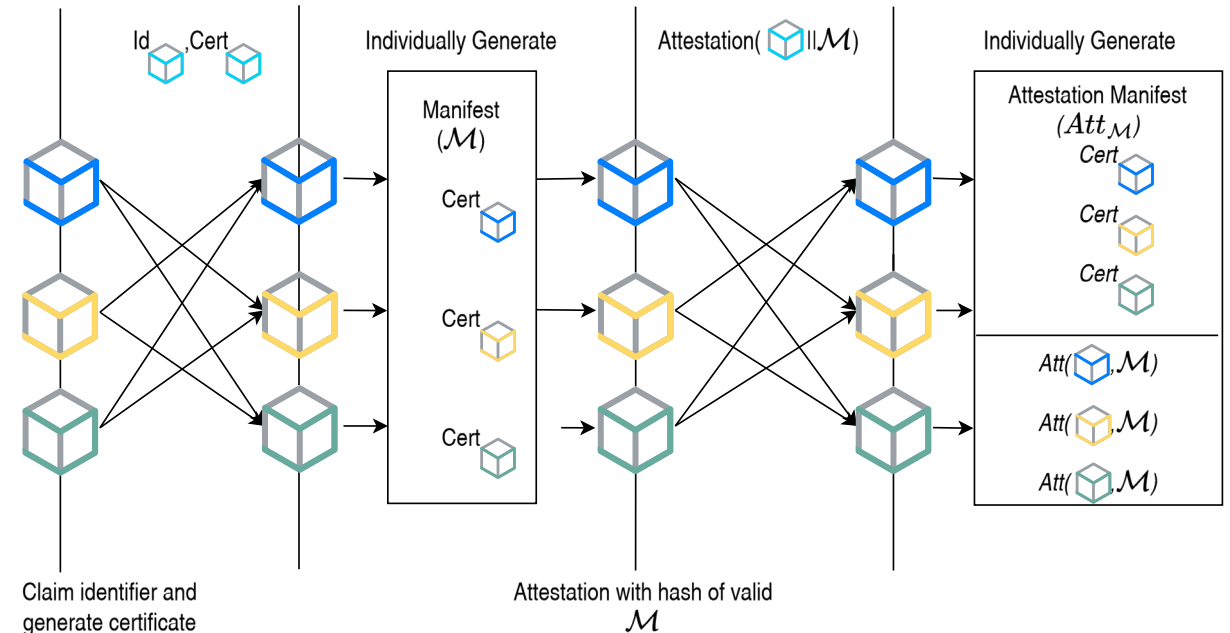
# Consensus on the config

## Attestation sidecar:

- Pods initialize with list of pods (untrusted)
- On startup **generate a fresh CA Certificate** and a **Leaf Certificate** signed by the CA
- **Phase 1:** exchange identifier and CA certificate and construct manifest
  - Duplication not allowed
- **Phase 2:** Exchange attestation evidence bound to manifest
  - Evidence binds  $\text{SHA256}(\text{Manifest} || \text{pod})$  to REPORTDATA register

## Result:

- Pods have a way to prove who they are and prove what the application is
- No verification → No trust



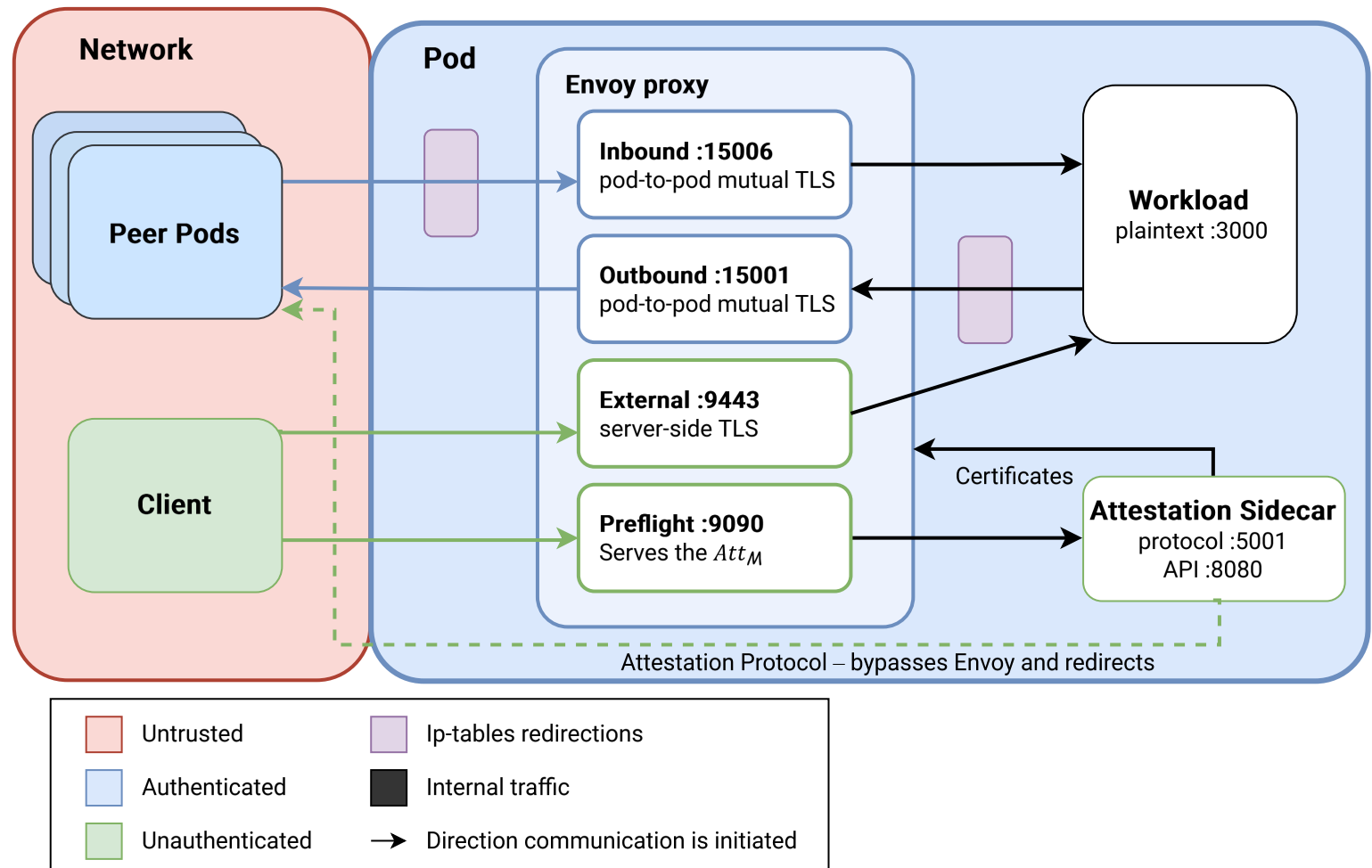
# Secure channels between pods

Init Container forces app to communicate through proxy

Credentials are released by attestation sidecar

- Proxy unblocked, app allowed to communicate

Workloads cannot initiate connections outside the application



# Verification by outside relying parties

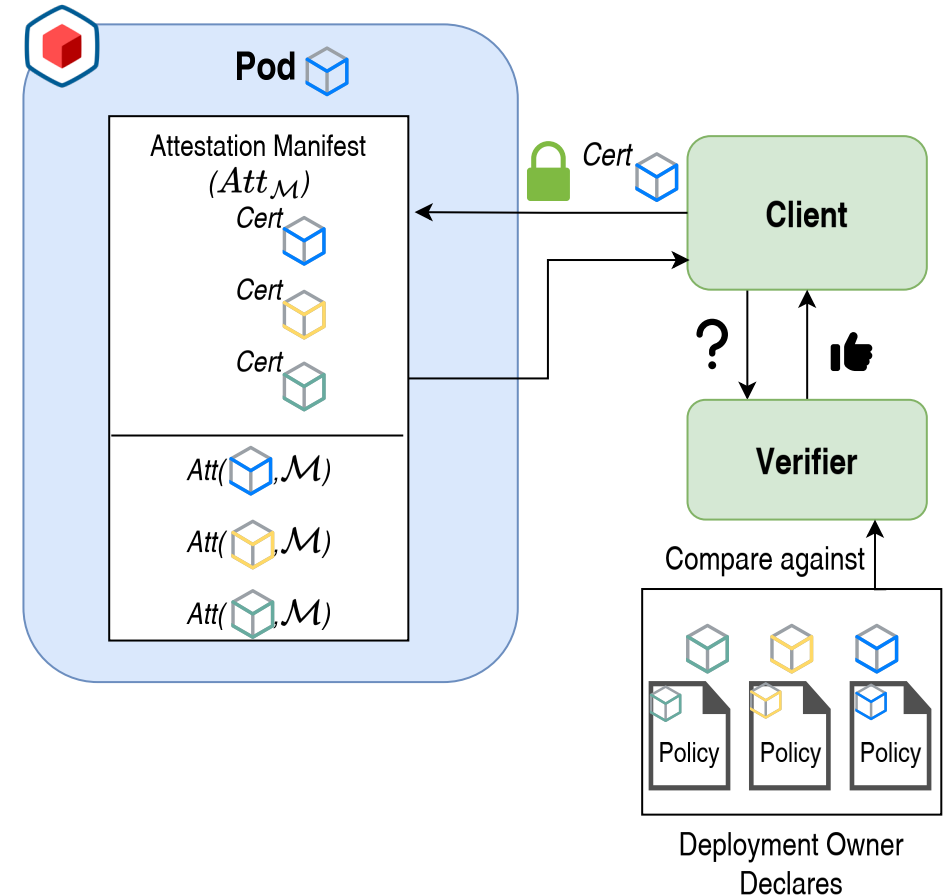
## Attestation manifest is exposed by each pod

### Verifier checks each attestation

- All attestations are bound to the (same) manifest
- Attestations match an appraisal policy
  - Hardware type, kata-tdx CVM images, container image hashes, etc.

### Relying parties can pin certificates

- A replayed attestation manifest fails at TLS-level



# Demo app

7 services, ported without touching code

Adoption cost depends on how much application assumes of underlying platform

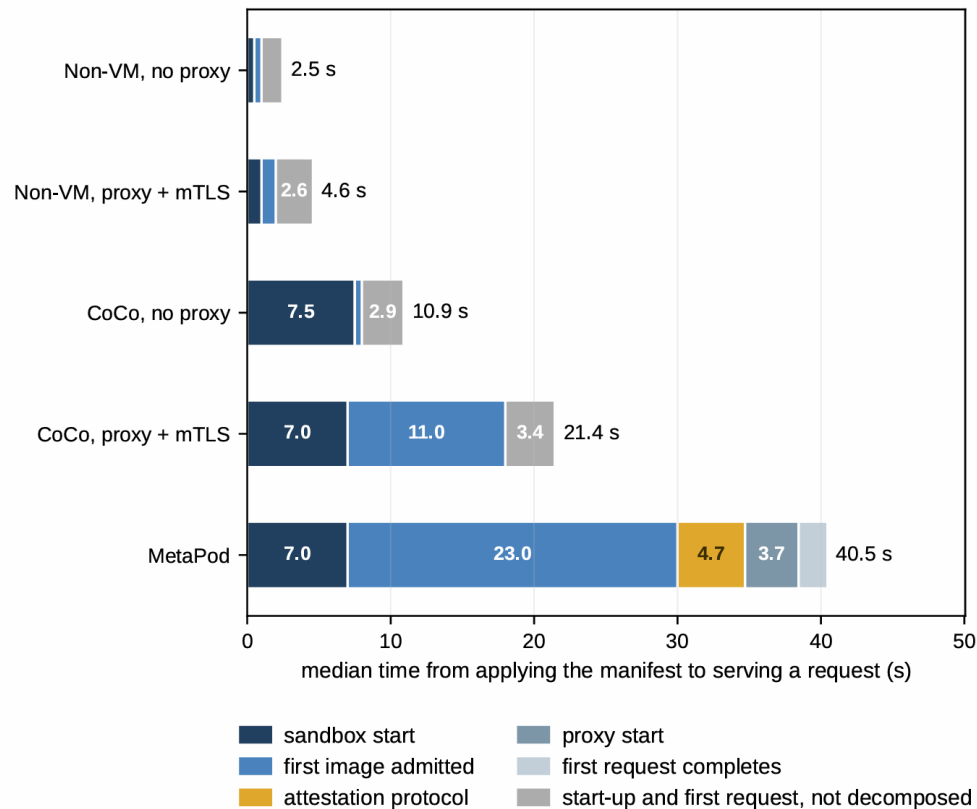
- 9 types of black-box changes
- 4 problems requiring knowledge of what app does
- 601 → 1141 lines of k8s deployment spec

| Change                                                                                                                       | Trigger     |
|------------------------------------------------------------------------------------------------------------------------------|-------------|
| <i>Applied to every workload</i>                                                                                             |             |
| Deployment → StatefulSet with <code>serviceName</code>                                                                       | MetaPod     |
| Headless Service for stable DNS and peer discovery                                                                           | MetaPod     |
| Confidential-runtime annotations and <code>runtimeClassName</code>                                                           | CoCo        |
| iptables init container, attestation and proxy containers                                                                    | MetaPod     |
| Shared volumes for composition, proxy config, CA bundle                                                                      | MetaPod     |
| Images referenced by digest                                                                                                  | MetaPod     |
| Startup, readiness, liveness probes removed                                                                                  | MetaPod     |
| <i>Applied to specific workloads</i>                                                                                         |             |
| External service port retargeted to proxy ( <i>store-front</i> , <i>store-admin</i> )                                        | MetaPod     |
| Dependency-wait init container removed ( <i>order-service</i> )                                                              | MetaPod     |
| Numeric <code>runAsUser</code> + <code>supplementalGroups</code> to restore the dropped sudo group ( <i>documentdb</i> )     | CoCo †      |
| Block-encrypted <code>emptyDir</code> for the data dir; <code>DATA_PATH</code> moved to a clean subdir ( <i>documentdb</i> ) | CoCo †      |
| VM memory raised for large image ( <i>documentdb</i> )                                                                       | CoCo †      |
| Gateway binary recompiled for x86-64-v2 ( <i>documentdb</i> )                                                                | CoCo, TDX † |

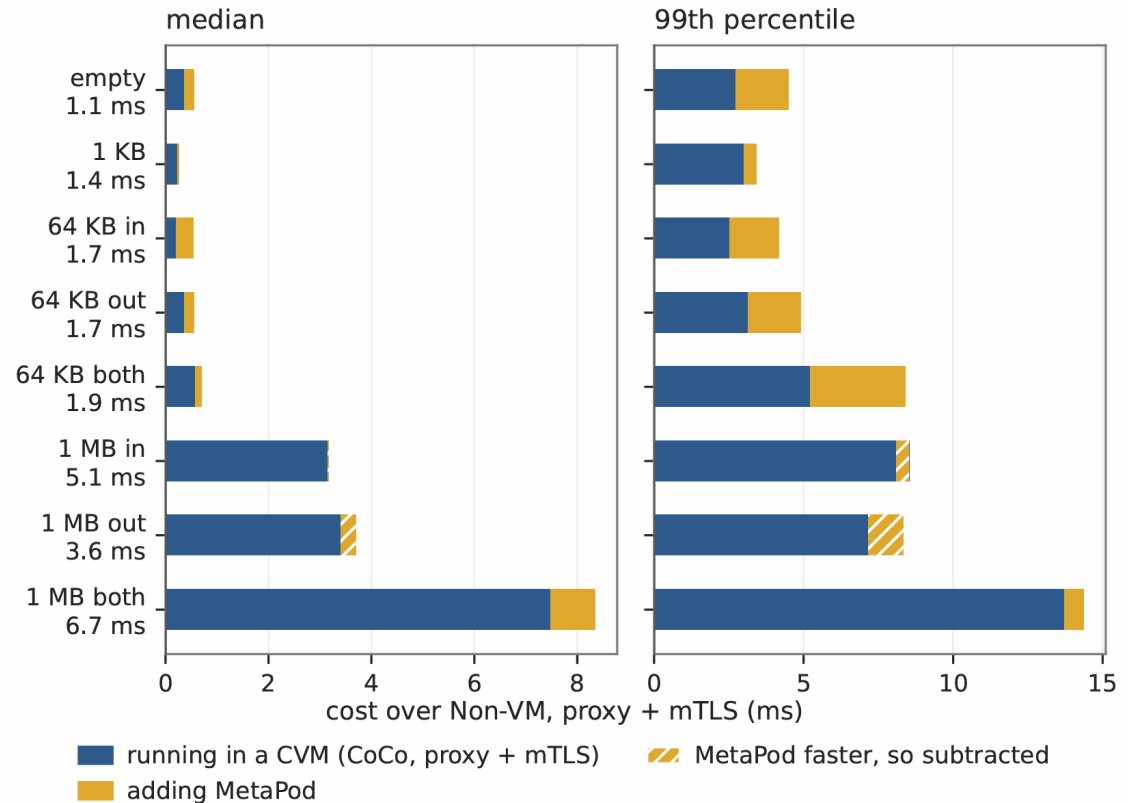


# Performance

- Most deployment time comes from fetching and starting images



- Small payloads slightly slower, around 0.5 ms
- Large payloads very similar



# Takeaways

**Attestation allows us to establish trust in remotely-hosted applications**

**Attesting individual pods isn't enough: we need to attest the whole application at once**

**We can achieve this by attesting application containers along with a common proxy configuration**

